

# PASTA Threat Modeling Worksheet

Process for Attack Simulation and Threat Analysis - representative customer account portal

## Stage 1 - Define Business Objectives

- Protect customer account data, authentication integrity, payment/profile information, and service availability.
- Prevent unauthorized account takeover, fraudulent transactions, and exposure of regulated or confidential data.
- Maintain traceable security events for investigation and compliance.

## Stage 2 - Define Technical Scope

- Public web application and API gateway
- Identity provider and MFA service
- Application server and database
- Cloud object storage for documents
- Email/SMS notification provider
- Administrative console and support workflows

## Stage 3 - Application Decomposition

| Component               | Trust boundary / data flow        | Security concern                                      |
|-------------------------|-----------------------------------|-------------------------------------------------------|
| Browser / mobile client | Untrusted internet -> application | Session theft, malicious input, credential abuse      |
| Identity provider       | Client/application -> IdP         | MFA bypass, password attacks, token misuse            |
| API                     | Internet/app -> service layer     | Broken authorization, injection, rate abuse           |
| Database                | Application -> data store         | Excessive service privileges, sensitive-data exposure |
| Admin console           | Admin network -> management plane | Privileged compromise, weak access review             |
| Third-party messaging   | Application -> external provider  | Data minimization, token/secret handling, vendor risk |

## Stage 4 - Threat Analysis

- Credential stuffing and phishing against customer or support accounts.
- Broken object-level authorization exposing another user's records.
- Injection or unsafe input leading to unauthorized data access.
- Session/token theft through compromised endpoint or insecure storage.
- Abuse of password-reset or support processes to bypass normal authentication.
- Cloud-storage misconfiguration exposing uploaded customer documents.

## Stage 5 - Vulnerability Analysis

- Insufficient rate limiting or anomaly detection around authentication.
- Authorization checks implemented inconsistently across API endpoints.
- Broad application/service-account permissions.
- Secrets stored with excessive access or weak rotation.
- Incomplete administrative logging and alerting.

## Stage 6 - Attack Modeling

| Attack scenario      | Path                                                                                   | Likelihood | Impact | Priority |
|----------------------|----------------------------------------------------------------------------------------|------------|--------|----------|
| Account takeover     | Phishing/credential stuffing -> login -> token/session -> account actions              | High       | High   | Critical |
| Broken authorization | Authenticated low-privilege user -> manipulate object ID -> access another user's data | Medium     | High   | High     |
| Admin compromise     | Stolen admin credential -> management console -> broad data/system access              | Medium     | Severe | Critical |
| Data exposure        | Cloud configuration error -> public object access -> sensitive document retrieval      | Medium     | Severe | Critical |

## Stage 7 - Risk & Impact Analysis / Recommended Controls

- **Identity:** Phishing-resistant MFA for administrators, adaptive authentication, credential-stuffing detection, secure reset procedures.
- **Authorization:** Server-side object authorization, deny-by-default access, automated authorization tests, least-privilege service roles.
- **Application security:** Input validation, parameterized queries, secure session handling, dependency management, code review.
- **Monitoring:** Centralized authentication/admin/API logs, anomaly alerts, high-risk action monitoring, consistent time synchronization.
- **Cloud/data:** Private-by-default storage, encryption, key governance, data minimization, DLP where appropriate.
- **Response:** Account-takeover playbook, token revocation, credential reset, evidence preservation, customer notification workflow.